

Information Risk and Security Management

WM279 Information Risk and Security Management

Author Student ID: u5602780

Module Tutor: Dr. Maria Papadaki

January 16, 2026

Written report
Word Count: 2170

Contents

1	Introduction and Scope	2
2	Critical Literature Review	2
2.1	Strengths and Challenges of IIoT devices in warehouses	2
3	Risk Analysis	3
3.1	Asset Register	3
3.2	Analysing Publicly Known Vulnerabilities	5
3.3	Threat Register	5
3.4	Risk Register	7
3.5	Proposed IIoT Risk Mitigation Framework	7
3.6	Evaluation of Two Most Severe Risks	7
4	Recommendations	8
4.1	Summary Table of Six Recommendations	8
4.2	Top Three Recommendations with Critical Discussion	8
A	Appendix: Assumptions and Limitations	10
A.1	Assumptions	10
A.2	Limitations	10
B	Appendix: Analysis of existing vulnerabilities	11
C	Appendix: MITRE D3FEND Vulnerability to CAPEC to Mitigation Graph	12
D	Appendix: GAIT Usage	13

1 Introduction and Scope

This assessment covers the 150,000m² warehouse’s IIoT ecosystem, specifically the seven asset classes (AN1–AP4) Table 1 bridging the IT/OT network. The analysis is limited to deliberate cyberattacks and exploitation of technical vulnerabilities (CVEs) using the STRIDE and ISO 27005:2024 frameworks to calculate risk via reproducibility, business value Table 2, and CIA impact Table 4. It was decided to use bespoke formula to derive risk over DREAD [8] as it allows for better structure in the current context. For the Risk Register, a qualitative reproducibility metric was selected over the EPSS model [3], as this frequency estimation framework would be too narrowly focused, undermining the report’s goal on supporting continued use of all listed IIoT devices in the current environment. Explicitly excluded are environmental hazards, accidental failures, and social engineering, ensuring a strictly technical focus on the digital “blast radius” of the deployed systems.

2 Critical Literature Review

Rodriguez et al. [11] qualitatively analyse warehouse cybersecurity via 40 expert interviews and five site observations, identifying 26 operational and cyber vulnerabilities. While providing useful practitioner insight, the lack of transparency in expert selection criteria and facility size limits reproducibility and utility. Furthermore, vulnerabilities are neither quantified nor ranked by likelihood or impact, hindering their utility in prioritised risk management. While serving as a checklist for control coverage, the study lacks the qualitative depth required for evidence-based risk scoring or audit sampling.

Junejo et al. [7] propose a layered threat model for IoT-enabled logistics using a partial OSI framework to classify threats into interception, interruption, modification, and fabrication. Although this supports systematic technical risk identification, threats are not derived from incidents or weighted by frequency. Consequently, the model aids control design but fails to support different risk appetites or cost–benefit analysis. From an assurance perspective, the framework helps map technical controls, such as encryption, to network layers. Its narrow technical focus provides deep, focused research.

Jarasuniene et al. [6] analyses IIoT adoption through literature and nine expert interviews, citing benefits like real-time visibility and barriers such as high costs and privacy concerns. However, the reliance on expert opinion without statistical validation introduces bias to be aware of. The findings emphasise strategic and operational risks over concrete cyber scenarios, informing maturity assessments regarding skills and governance but offering limited guidance for technical audit assurance.

Effective oversight must focus on role-based access in multi-user environments, availability controls against denial-of-service, and governance over SaaS or Robotics-as-a-Service providers. Ultimately, while current literature identifies key vulnerabilities, the lack of quantitative grounding restricts rigorous risk scoring, reinforcing the need for empirically driven IIoT assessment frameworks.

2.1 Strengths and Challenges of IIoT devices in warehouses

IIoT adoption has substantial operational gains: approximately 80% of specialists report improved maintenance costs, lead costs, and customer satisfaction [6]. These benefits justify investment but increase digital dependency, elevating the “impact” component of cyber risk. This necessitates robust business continuity planning and higher tolerance thresholds for system availability.

In contrast, cyber exposure is significant: Importantly 17% of security professionals identify IoT endpoints as a major security challenge [11], and a third of targeted attacks succeed [2]. These

figures demand risk-based prioritisation of controls for information management, and network resilience.

IIoT adoption also represents a long-term commitment to specific vendors and software ecosystems [6]. Limited interoperability, poor standardisation, and compatibility constraints between warehouse technologies complicate system integration and upgrades, leading some studies [11, 6] to suggest that medium-sized warehouses may benefit from developing bespoke solutions. These issues are exacerbated by legacy systems, which, while operationally stable, are costly to modernise and often lack timely security patching, increasing susceptibility to exploitation [11].

3 Risk Analysis

The objective of this section is to provide a structured approach for deriving threats and risks from known vulnerabilities. A primary challenge lies in the limitations of the data scope. This work relies on discovered CVEs for the provided assets to build an exhaustive, threat-based risk analysis. This approach will allow us to account for discontinued legacy devices and their continued usage.

3.1 Asset Register

Device descriptions, pricing collected from the vendors/suppliers, and firmware versions (where available).

Table 1: Asset List with IDs

Asset Name	No.	Asset Description	Asset Price	Asset Firmware
EcoStruxure Link150 Gateway	AN1	Network gateway with power and network usage metrics	£773.05	v5.3.7
Zebra FX9600 RFID Reader	AI1	RFID reader for automated inventory tracking	£1163.99	v3.31.22
MOCREO Smart PIR Sensor	AP1	Passive infrared sensor used to detect movement in warehouse	N/A	No public firmware reference
Honeywell HVAC T6 Pro Room Thermostat	AS1	Thermostat used to manage temperature	£67.55	ZW_T6_RM_V03.01.00.00
Axis P1468-LE Camera	AP2	Fixed outdoor network surveillance camera	£1216.94	11.11.181 (AXIS OS)
Tuya Smart Camera U6N	AP3	Indoor smart surveillance camera	N/A	Automatic update by manufacturer
Foscam FI8620 IP Camera	AP4	Network-connected surveillance camera	£550	v20120401

The following table evaluates Individual Asset Impact based on the perceived criticality of each asset. Scores are weighted across three primary dimensions: Business Impact, Operational Dependency, and Security Impact.

Table 2: Asset Criticality Assessment in order

Asset No.	Business Impact 25%	Dependency 45%	Security Impact 30%	Total Score
AN1	1.0	1.0	0.5	0.85
AI1	0.9	0.7	0.4	0.66
AP1	0.6	0.4	0.7	0.54
AS1	0.7	0.6	0.3	0.53
AP2	0.5	0.4	0.7	0.51
AP3	0.5	0.4	0.7	0.51
AP4	0.5	0.4	0.7	0.51
Score Legend: Score = $BI \times 0.25 + D \times 0.45 + SI \times 0.3$				

The following graph illustrates the contribution of IT assets to essential business functions, as outlined in ISO 27005:2024 [1]. Notably, network security plays a central role in maintaining business operations, other components are critically dependent upon it.

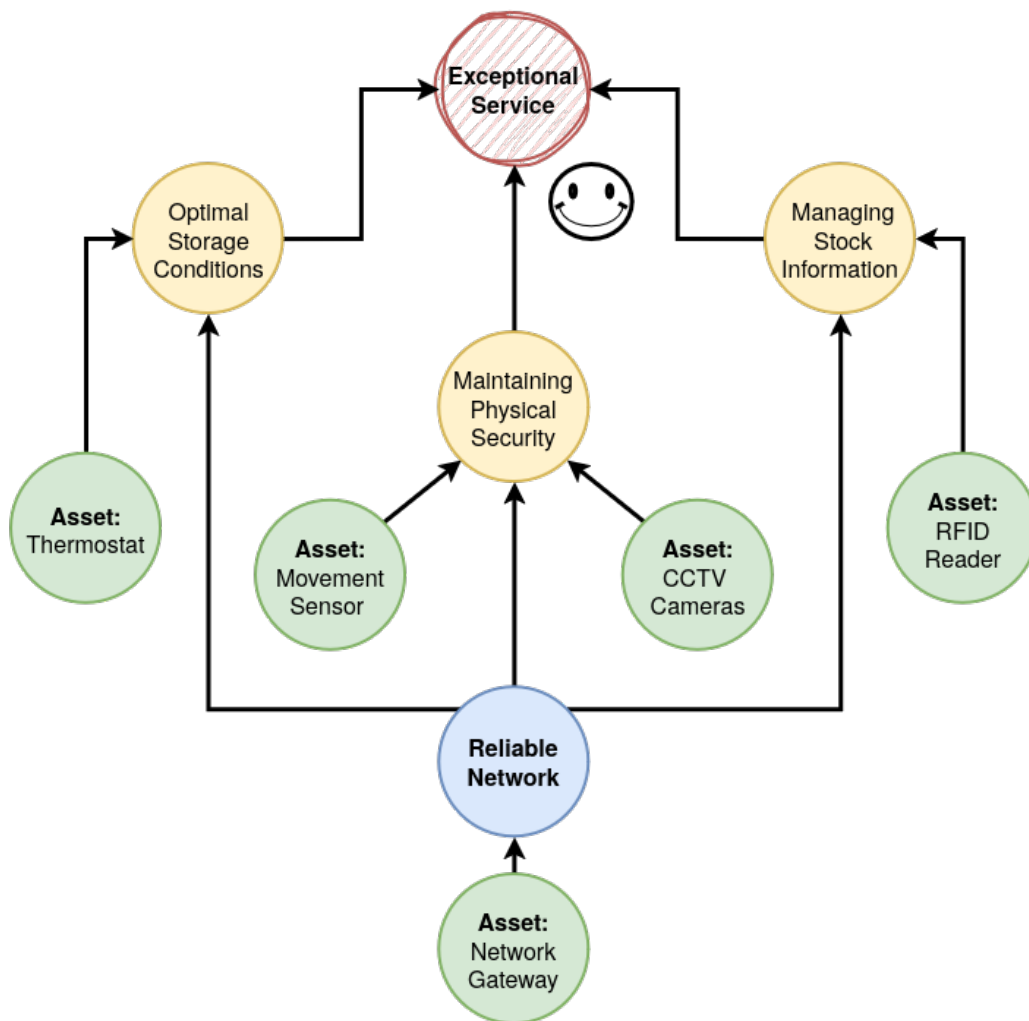


Figure 1: Asset Dependency Graph

3.2 Analysing Publicly Known Vulnerabilities

This section analyses the vulnerabilities identified in Appendix B. While it is encouraging that there are no publicly known vulnerabilities for current software versions on these devices, it remains essential to derive the threats these devices may face during continuous operation. In this context, a comprehensive collection of potential vulnerabilities serves as a vital foundation for risk assessment.

Table 3: Classes of Vulnerabilities

Class Index	Class Type	Description
V1	Unauthorised Access	Access to resources without proper authorisation, potentially exposing sensitive data.
V2	Privilege Escalation	Exploits that allow a user to gain higher access rights than intended.
V3	Arbitrary Code Execution	Ability to execute any code on the target system, leading to full system compromise.
V4	File Upload / Path Traversal	Uploading malicious files or manipulating file paths to access restricted areas.
V5	Secure Boot Bypass	Circumventing secure boot mechanisms to load untrusted code during system startup.
V6	Denial of Service (DoS)	Exploits that can make a system or service unavailable, impacting operations.

3.3 Threat Register

The combination of derived vulnerability classes and expert opinions from [11, 6, 7] are used to determine possible threats using the STRIDE framework [8] in Table 5

It is important to recognise that not all threats are equal in potential impact. Here the CIA Triad comes to good use, with Low, Medium and High Impact Values further calculated the average impact of the threat.

Table 4: Threat Assessment Using the CIA Triad

Threat No.	Confidentiality	Integrity	Availability	Normalised Score
TN2	1.0	1.0	1.0	1.00
TI1	1.0	1.0	1.0	1.00
TN1	1.0	1.0	0.66	0.89
TN5	1.0	1.0	0.66	0.89
TI2	1.0	1.0	0.66	0.89
TN4	1.0	1.0	0.33	0.78
TS1	0.33	1.0	1.0	0.78
TP1	1.0	0.66	0.66	0.77
TP3	0.66	0.66	0.66	0.66
TP4	0.33	1.0	0.66	0.66
TN3	0.33	0.33	1.0	0.55
TP2	0.33	0.66	0.66	0.55
TI3	0.33	0.66	0.66	0.55
Score Legend: 0.33 = Low, 0.66 = Medium, 1.0 = High				
$x > 0.3$: Low	$x > 0.6$: Medium		$x > 0.8$: High	

Table 5: Types of Threats Derived from Vulnerabilities

Category	No.	Threat description	Cause	CIA element affected
Network Reliability	TN1	Network compromise via unauthorised access	V1	C, I, A
	TN2	Ransomware attack exploiting privilege escalation	V2	C, I, A
	TN3	Denial of Service (DoS)	V6	A
	TN4	Man-in-the-Middle / Data integrity attack leveraging insecure device access and privilege escalation	V1, V2	C, I
	TN5	Remote code execution through network services	V3	C, I, A
Optimal Storage Conditions	TS1	Communication of incorrect storage conditions via compromise of device	V1	I, A
Managing Stock Information	TI1	Data system compromise via unauthorised access	V1	C, I, A
	TI2	Arbitrary code execution affecting stock management	V3	C, I, A
	TI3	Unauthorised file upload affecting storage integrity	V4	I, A
Managing Physical Security	TP1	CCTV system compromise via privilege escalation or arbitrary code execution	V2, V3	C, A
	TP2	Movement sensor compromise via unauthorised access	V1	I, A
	TP3	Unauthorised file uploads affecting sensor operation	V4	I, A
	TP4	Device tampering due to secure boot bypass	V5	I, A

3.4 Risk Register

Risk is commonly defined as the impact of a vulnerability on a system’s healthy operation multiplied by the likelihood of that vulnerability occurring. This assessment calculates risk using the following formula:

$$\text{Risk} = \text{Reproducibility} \times \text{Threat CIA} \times \text{Asset Business Value}$$

Table 6: Updated Risk Assessment (Sorted by Total Risk)

Asset	Risk	Reproducibility	Threat Imp.	Asset Val.	Total
AI1	TI1 (Data Comp.)	1.00	1.00	0.66	0.660
AN1	TN2 (Ransomware)	0.66	1.00	0.85	0.561
AN1	TN3 (DoS)	1.00	0.55	0.85	0.468
AN1	TN4 (MitM)	0.66	0.78	0.85	0.438
AS1	TS1 (Storage Env)	1.00	0.78	0.53	0.413
AP1	TP2 (PIR Access)	1.00	0.55	0.54	0.297
AN1	TN5 (RCE)	0.33	0.89	0.85	0.250
AI1	TI3 (File Upload)	0.66	0.55	0.66	0.240
AP1	TP3 (File Upload)	0.66	0.66	0.54	0.235
AI1	TI2 (Code Exec.)	0.33	0.89	0.66	0.194
AP2-4	TP1 (CCTV Comp.)	0.33	0.77	0.51	0.130
AP2-4	TP4 (Secure Boot)	0.33	0.66	0.51	0.111
Reproducibility Scale: 0.33 = Hard 0.66 = Medium 1.00 = Beginner Level					

3.5 Proposed IIoT Risk Mitigation Framework

Acknowledging the limitations of any risk assessment, these measures are chosen to ensure resilience even against threats not explicitly modelled. The proposed Warehouse Risk Mitigation Strategy prioritises a **Defence-in-Depth** posture, aligning with the MITRE D3FEND framework to systematically break the attacker’s kill chain. By enforcing **Data Compartmentalisation** and **Credential Analysis**, the architecture adopts a Zero Trust model to prevent lateral movement during Network Compromise (TN1) and Unauthorised System Access (TI1, TP2). To mitigate the critical impact of Ransomware (TN2) and Man-in-the-Middle attacks (TN4), the strategy mandates **File Encryption** across data-at-rest and in-transit. Furthermore, the introduction of **Decoy Files** adds a layer of active deception to disrupt attacker reconnaissance, while high-availability redundancy ensures resilience against Denial-of-Service (TN3) and total operational cessation. Crucially, these measures enable the report’s goal of providing continuous support for legacy and discontinued devices on the system in the future.

3.6 Evaluation of Two Most Severe Risks

Quick Evaluation of main risks:

AI1 → TI1 **Data System Compromise**: Unauthorised access to the AI1 data system enables real-time interception and manipulation of critical stock information. This facilitates supply-chain side-channel attacks and establishes a persistent foothold for lateral movement into connected IoT devices and the wider network infrastructure.

AN1 → TN1 **Network Compromise**: Compromising the AN1 network gateway provides a strategic entry point for deep packet inspection and lateral movement. This grants attackers the capability to execute a total warehouse communication shutdown, resulting in a complete cessation of operational throughput.

4 Recommendations

This section provides recommendations to address maximum risks with minimal system changes, offering a quick, cost-effective way to break the attacker’s kill chain; removing even one step can stop the attack as proposed by MITRE ATT&CK [10]. We use the MITRE D3FEND framework [9] for structured analysis. Mitigating a threat requires addressing its vulnerabilities, which can be done by mapping CVEs to attacker techniques using the tool presented at Black Hat Europe 2025 [4]. This approach translates vulnerabilities into actionable defences, directly disrupting attacker behaviour Appendix C.

4.1 Summary Table of Six Recommendations

The following recommendations integrate D3FEND strategies with targeted IoT deployment practices described by experts in literature to neutralise the vulnerability classes identified in the risk register. By aligning these perspectives, the strategy provides a defence-in-depth posture specifically designed to disrupt the exploitation of the warehouse’s current CVE profile.

Table 7: Top 6 Security Recommendations and D3FEND Strategies

Recommendation	Brief Rationale
Data Compartmentalisation	Segregate sensitive information to limit the blast radius and impact of potential privacy breaches.
Data Anonymisation	Protect individual privacy by anonymising employee and customer data within the core system architecture.
Static Data Environments	Use disconnected environments for IoT analysis to shield live databases from external vulnerabilities.
Harden: File Encryption D3F-D3-FE	Encrypt files at rest and in transit to ensure stolen data is valueless to an unauthorised actor.
Detect: Credential Analysis D3F-D3-CCSA	Monitor logon history to identify compromised credentials across diverse supplier systems and devices.
Deceive: Decoy Files D3F-D3-DF	Use honey-files to provide fake intel to attackers and serve as an early-warning system for intrusions.

4.2 Top Three Recommendations with Critical Discussion

The primary defensive strategy for the warehouse must prioritise **Credential Analysis (D3F-D3-CCSA)** due to its high feasibility and direct impact on the most prevalent threats identified in the audit. By implementing SIEM-based monitoring of log-in history, the organisation can achieve immediate detection of account takeovers, significantly reducing attacker dwell time across critical assets like the EcoStruxure gateway and stock management systems. This shift toward a **Zero Trust Architecture** ensures that compromised credentials do not grant indefinite access to the IIoT ecosystem.

Supplementing this, **File Encryption (D3F-D3-FE)** serves as a vital secondary control to mitigate the organisational consequences of Ransomware (TN2) and Man-in-the-Middle (TN4) attacks. While requiring more complex key management, encryption neutralises the value of exfiltrated data, effectively preventing “double-extortion” tactics and ensuring compliance with **UK GDPR** [5] and **ISO/IEC 27001** data protection mandates.

Finally, **Data Compartmentalisation** through the use of VLANs and Network ACLs is recommended to break the attack chain between vulnerable IoT sensors (such as the Axis and Tuya cameras) and core stock systems. This **Defence-in-Depth** approach is highly feasible and essential for isolating potential security breaches from network operations, preventing the lateral movement that could lead to a total warehouse communication shutdown.

References

- [1] Iso/iec 27005:2024 – information security, cybersecurity and privacy protection – guidance on managing information security risks, 2024. Fourth edition, based on ISO/IEC 27005:2022 guidance; available from ISO or national standards bodies.
- [2] Accenture. Accenture survey: One in three cyberattacks result in a security breach, yet most organizations remain confident in their ability to protect themselves. <https://newsroom.accenture.com/news/2016/accenture-survey-one-in-three-cyberattacks-result-in-a-security-breach-yet-most-orga> Nov 02 2016. Accessed: 2026-01-05.
- [3] FIRST.org. Epss model, 2026. URL <https://www.first.org/epss/model>. Accessed: 2026-01-15.
- [4] Galeax. CVE2CAPEC: Generate mitre att&ck and d3fend from a list of cves. <https://galeax.github.io/CVE2CAPEC/>, 2025. Showcased at BlackHat Europe 2025 Arsenal, an open-source tool demonstration event.
- [5] Information Commissioner’s Office. Encryption – a guide to data security. Online guidance on encryption under UK GDPR, 2025. URL <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/security/a-guide-to-data-security/encryption/>. Accessed: 2026-01-05.
- [6] Aldona Jarašūnienė, Kristina Čižiūnienė, and Audrius Čereška. Research on impact of iot on warehouse management. *Sensors*, 23(2213), 2023. doi: 10.3390/s23042213. URL <https://doi.org/10.3390/s23042213>.
- [7] Aisha Kanwal Junejo, Michael Breza, and Julie A. McCann. Threat modeling for communication security of iot-enabled digital logistics. *Sensors*, 23(9500), 2023. doi: 10.3390/s23239500. URL <https://doi.org/10.3390/s23239500>.
- [8] Microsoft Corporation. Microsoft threat modeling tool – threats. Online documentation on identifying and categorizing threats using the Microsoft Threat Modeling Tool, 2022. URL <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>. Accessed: 2026-01-05.
- [9] MITRE Corporation. MITRE D3FEND: A knowledge graph of cybersecurity countermeasures, 2023. URL <https://d3fend.mitre.org/>.
- [10] MITRE Corporation. MITRE ATT&CK: Adversarial tactics, techniques, and common knowledge. <https://attack.mitre.org/>, 2026. Accessed: 2026-01-05.
- [11] Miguel Rodríguez García, Kellen Betts, and Eva Ponce. Mit’s warehouse of the future initiative: Results from field research and a literature review, February 2025.

A Appendix: Assumptions and Limitations

A.1 Assumptions

To ensure a consistent and systematic risk analysis, the following baseline assumptions have been established:

- **Operational Priority:** The primary objective is the maintenance of high-availability and uninterrupted service, prioritising Availability within the CIA triad.
- **Firmware Integrity:** Assets are assumed to run the latest Long-Term Support (LTS) firmware. Where LTS documentation is unavailable, the most recent stable public release is assumed.
- **Organisational Maturity:** Despite the lack of formal internal policy documentation, it is assumed the organisation follows industry-standard security hygiene (e.g., basic firewalling) as a baseline.
- **Vendor Lock-in:** Recommendations are constrained by the existing hardware footprint; the analysis assumes hardware replacement is not a viable short-term mitigation strategy.

A.2 Limitations

- **Information Asymmetry:** The absence of internal network topology diagrams and specific Access Control Lists (ACLs) necessitates a reliance on generalised best practices rather than bespoke configuration audits.
- **Residual Risk Constraints:** Quantitative residual risk cannot be calculated with high confidence due to a lack of historical breach data or current security telemetry. Therefore, scoring remains primarily qualitative.
- **Scope Exclusion:** This technical audit focuses strictly on the digital "blast radius." Human-centric risks (Social Engineering), physical security breaches (tailgating), and environmental hazards are explicitly out of scope.

B Appendix: Analysis of existing vulnerabilities

Table 8: Analysis of Existing Classes of Vulnerabilities (Updated with EPSS)

Vuln Index	Class (Type)	Device	CVE	CVSS	EPSS (Prob)	Version Affected	Possible threat
V1	Unauthorised Access	AN1	CVE-2024-10575	10.0	0.3%	1.21.0.6 - 1.23.0.4	Unauthorised access due to missing controls.
		AP4	CVE-2013-2574	7.5	30.5%	N/A	Insufficient access restrictions to the sensitive log information.
V2	Privilege Escalation	AN1	CVE-2024-0865	7.8	0.11%	prior 1.21.0	Hard-coded credentials could cause local privilege escalation when logged in as a non-administrative user.
		AP2	CVE-2025-5452	6.7	0.06%	AXIS OS 12.0 - 12.6.68	Malicious applications may obtain administrative credentials, enabling privilege escalation.
		AP2	CVE-2025-5454	6.7	0.03%	AXIS OS 12.0 - 12.6.17	Path traversal vulnerability allowing elevated privileges on the device.
		AP2	CVE-2025-5718	6.7	0.06%	AXIS OS 12.0 - 12.6.29	Symlink attack enabling unauthorised privilege escalation.
		AP2	CVE-2025-6779	6.7	0.02%	AXIS OS 12.0 - 12.6.39	Command injection risk leading to potential privilege escalation.
		AP2	CVE-2025-8108	6.7	0.02%	AXIS OS 12.0 - 12.7.32	Improper permissions and input validation allowing privilege escalation.
V3	Arbitrary Code Execution	AN1	CVE-2020-10626	7.8	0.07%	2.2.2 and prior	Execution of malicious code through DLL hijacking.
		AP2	CVE-2025-4645	6.7	0.03%	AXIS OS 12.0 - 12.6.6	Arbitrary code execution through insufficient input validation.
V4	File Upload / Path Traversal	AI1	CVE-2021-32089	9.8	1.64%	N/A	Unauthorised file upload leading to information disclosure or code execution.
		AI1	CVE-2020-10875	7.5	0.56%	N/A	Remote path traversal enabling unauthorised file access.
V5	Secure Boot Bypass	AP2	CVE-2023-21414	6.8	0.01%	AXIS OS 10.11 - 11.5	Bypass of secure boot protections allowing device tampering.
V6	Denial of Service	AP3	CVE-2024-32268	6.8	0.27%	v.3.2.5	Remote denial of service through crafted network packets.

No publicly available vulnerabilities were found for the MOCREO and Honeywell devices; therefore, they are excluded from this analysis.

C Appendix: MITRE D3FEND Vulnerability to CAPEC to Mitigation Graph

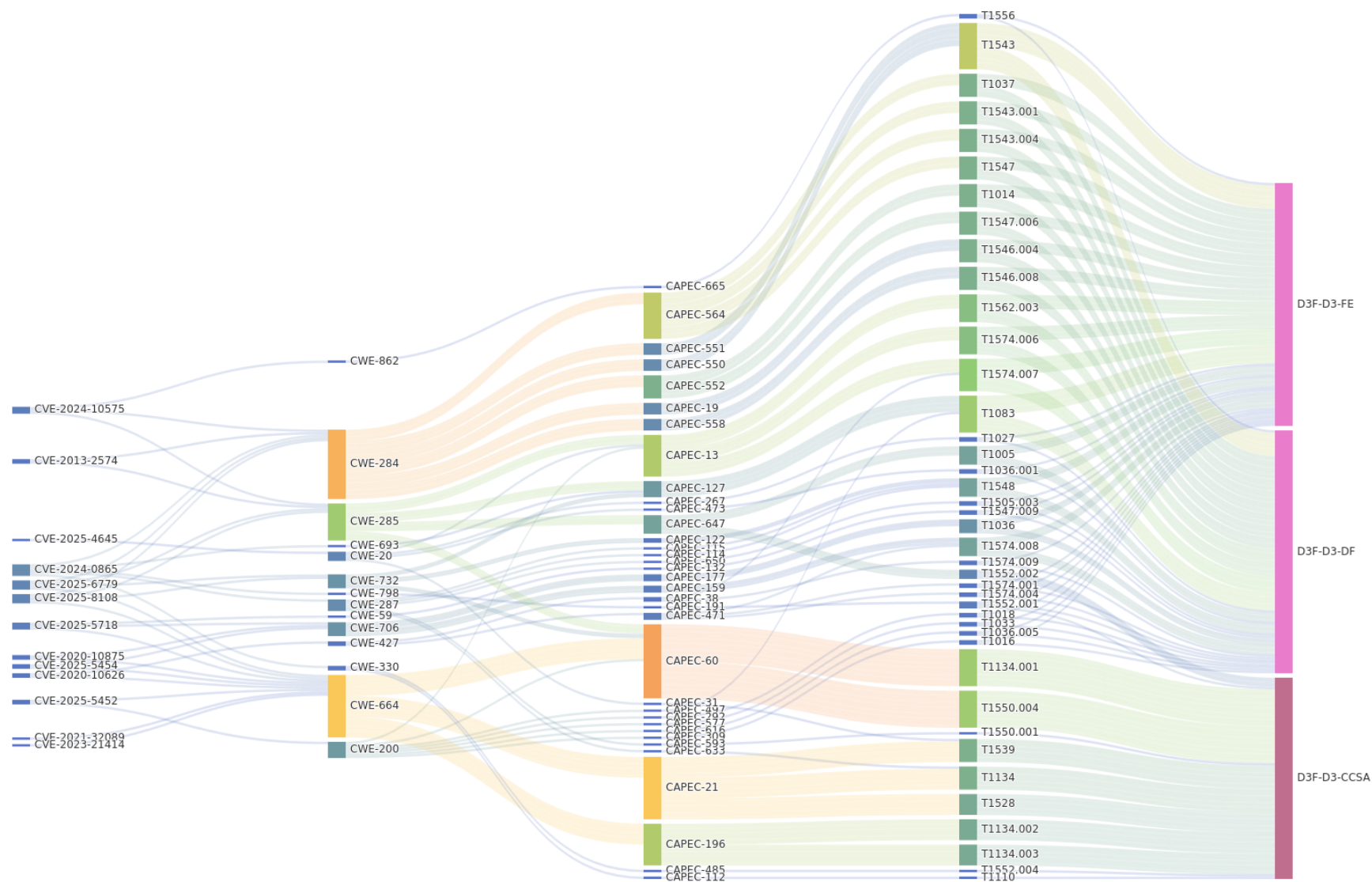


Figure 2: D3FEND Main Recommendations

D Appendix: GAIT Usage

The usage of GAIT tools was limited to evaluating the work against the coursework brief, performing grammar checks, and assisting with L^AT_EX formatting and compilation issues. The specific prompt used for evaluation was: “Is there anything I have missed or went off topic? Be rigorous and think a lot.”